

Responsible Use & Safety Scope — Ultron

Ultron is built to assist **authorized** penetration testers, not to conduct unsupervised or unauthorized offensive security activity. This document defines the guardrails the team has designed in (or is committing to close before deployment) and is intended for hackathon judges evaluating the project's safety posture.

1. Authorization-First Design

- No scan, exploit, or reconnaissance tool may run against a target that has not been explicitly registered via `start_engagement` with a signed authorization reference (see `TOOL_SCHEMA_REFERENCE.md`).
- The orchestration layer — not the model — is the enforcement point for scope. The model is treated as untrusted with respect to authorization decisions: even if it proposes an out-of-scope action, the system must reject it.
- All authorized targets and their engagement window (start/end date) are recorded before any tooling is invoked.

2. Human-in-the-Loop for Higher-Impact Actions

- Every action classified `risk_level: medium` or `high` must route through `request_human_confirmation` and receive explicit operator approval before execution.
- Read-only actions (recon discovery, vulnerability reference lookups) may proceed without per-call confirmation, but are still logged.
- The system defaults to the more cautious risk tier when uncertain — ambiguous actions are treated as `high` until a human classifies them otherwise.

3. Logging & Audit Trail

- Every tool call (model-proposed and human-approved), its arguments, and its result are logged with a timestamp and the identity of the approving operator.
- Logs are retained per-engagement and are not shared across engagements, to avoid cross-client data leakage.
- The final report (`generate_report`) is generated only from logged, approved findings — never from unlogged model output.

4. Data Handling

- Target data (hostnames, IPs, discovered credentials, scan output) is treated as client-confidential and scoped to its engagement.
- The fine-tuning dataset does not contain real client data (see `DATASET_CARD.md`); production engagement data must never be fed back into future training runs without explicit client consent and anonymization.

5. Model-Level Limitations Acknowledged

- The fine-tuned model has not been evaluated for robustness to prompt injection from tool outputs (e.g., a scanned service returning text designed to manipulate the agent's next action). Until evaluated, tool outputs are treated as untrusted input and are not allowed to directly trigger new tool calls without the same authorization/confirmation path.
- The model has not been red-teamed for its own jailbreak resistance. Deployment outside a supervised demo/lab context should wait for that evaluation (tracked in `EVALUATION_REPORT.md`).

6. Explicitly Out of Scope for This Project

- Fully autonomous, unsupervised exploitation of any system.
- Use against any target without a signed, current authorization reference.
- Generation or storage of working exploit payloads as training data or model output beyond referencing public CVE/CWE metadata.

7. Incident Response

- If the agent proposes or takes an action outside the registered scope, the engagement is halted immediately, the event is logged, and the finding is reported to the team lead before any further tool calls are permitted for that engagement.

8. Open Items Before Production Use

- ☐ Independent review of the authorization-enforcement code path (not just the model's behavior)

- ☐ Prompt-injection test suite using adversarial tool-output content
- ☐ Formal incident-response runbook beyond the summary above
- ☐ Legal sign-off template for the "authorization_reference" required by every engagement